

Module 3: Cybersecurity Ethics and Law

Ethical Dilemmas in Cybersecurity

- Security analysts often face situations where the right decision isn't clear, such as discovering a friend has unauthorizedly transferred data [cite: 54].
- Maintaining an unbiased stance and adhering to policies and protocols are crucial, regardless of personal relationships [cite: 54].

Key Ethical Principles and Methodologies

Security ethics are guidelines for making appropriate decisions as a security professional [cite: 55]. Being ethical requires that security professionals remain unbiased and maintain the security and confidentiality of private data [cite: 55].

- **Confidentiality:** Security professionals must protect proprietary and private information (like PII) and avoid unauthorized sharing, even to help a coworker [cite: 54]. Confidentiality as it relates to professional ethics means that there needs to be a high level of respect for privacy to safeguard private assets and data [cite: 56].
- **Privacy Protections:** Safeguarding personal information from unauthorized use is essential, meaning employee data should only be accessed and shared through official, secure channels [cite: 54]. To effectively safeguard PII and SPII data, security professionals hold an ethical obligation to secure private information, identify security vulnerabilities, manage organizational risks, and align security with business goals [cite: 56].

The Role of Law in Cybersecurity Ethics

- Laws are recognized rules enforced by governing entities that security professionals must follow [cite: 54].
- Negligence, such as leaving confidential files unsupervised, can lead to violations of compliance regulations and have legal consequences [cite: 54].
- As a security professional, you have an ethical obligation to protect your organization, its internal infrastructure, and the people involved [cite: 56]. You must remain unbiased and conduct your work honestly, responsibly, and with the highest respect for the law [cite: 56].
- Professionals must be transparent and just, and rely on evidence [cite: 56]. They should also stay informed and strive to advance their skills [cite: 56].

- An example is the Health Insurance Portability and Accountability Act (HIPAA), a U.S. federal law established to protect patients' health information (PHI) [cite: 56]. It prohibits patient information from being shared without their consent, and security professionals might help ensure the organization adheres to legal and ethical obligations to inform patients if their data is exposed [cite: 56].

Ethical Concerns and Laws Related to Counterattacks

- **U.S. Standpoint:** In the U.S., deploying a counterattack on a threat actor is illegal because of laws like the Computer Fraud and Abuse Act of 1986 and the Cybersecurity Information Sharing Act of 2015 [cite: 55].
- The act of counterattacking in the U.S. is perceived as an act of vigilantism, which refers to a person who is not a member of law enforcement deciding to stop a crime on their own [cite: 55].
- Because threat actors are criminals, counterattacks can lead to further escalation of the attack, which can cause even more damage and harm [cite: 55].
- If the threat actor is a state-sponsored hacktivist (a person who uses hacking to achieve a political goal), a counterattack can lead to serious international implications [cite: 55].
- For these reasons, the only individuals in the U.S. allowed to counterattack are approved employees of the federal government or military personnel [cite: 55].
- **International Standpoint:** The International Court of Justice (ICJ) states that a person or group can counterattack if: the counterattack will only affect the party that attacked first, it is a direct communication asking the initial attacker to stop, it does not escalate the situation, and the effects can be reversed [cite: 55].
- Organizations typically do not counterattack because these parameters are hard to measure, and negative outcomes are very difficult to control [cite: 56].

Key Takeaways

- As a future security professional, ethics will play a large role in your daily work [cite: 57].
- Understanding ethics and laws will help you make the correct choices if and when you encounter a security threat or an incident that results in a breach [cite: 57].